

Laboratório SOC Analyst N1 — Investigação de Movimento Lateral via PsExec

Cenário

Sou analista SOC Nível 1 da empresa fictícia **DeltaEnergy**.

Durante meu turno, o SIEM gerou um alerta relacionado ao uso da ferramenta **PsExec** em múltiplas máquinas da rede corporativa.

O alerta chamou atenção porque:

- o PsExec estava sendo executado remotamente
- houve autenticação administrativa incomum
- múltiplos hosts foram acessados em sequência

Meu objetivo era:

- validar se era atividade administrativa legítima
- identificar possível movimento lateral
- verificar hosts comprometidos
- coletar IOC
- escalar corretamente o incidente

Alerta recebido

Alert: Possible Lateral Movement via PsExec

Source Host: IT-WS-004

User: suporte.ti

Severity: High

Remote Targets:

FIN-PC-011

RH-PC-003

ADM-PC-008

Time:

2026-05-12 16:14:33

Primeira análise

Assim que visualizei o alerta, comecei avaliando alguns pontos importantes:

Evidência

Motivo

PsExec

ferramenta comum em movimento lateral

múltiplos hosts

propagação suspeita

autenticação administrativa

possível abuso de credenciais

sequência rápida

comportamento automatizado

Minha hipótese inicial foi:

- possível comprometimento com movimentação lateral

Investigando no Splunk

Comecei pesquisando os eventos relacionados ao host de origem.

Pesquisa inicial no Splunk

```
index=windows host="IT-WS-004"  
psexec
```

Resultado:

EventCode=4688

CommandLine:
psexec.exe \\FIN-PC-011 cmd.exe

CommandLine:
psexec.exe \\RH-PC-003 cmd.exe

CommandLine:
psexec.exe \\ADM-PC-008 cmd.exe

Analisando o comportamento

Nesse momento percebi:

- múltiplas conexões remotas
- uso administrativo incomum
- padrão compatível com movimentação lateral

Investigando autenticações

Meu próximo passo foi verificar:

- logins administrativos relacionados

Pesquisa Splunk — logins administrativos

index=windows EventCode=4624

Account_Name="suporte.ti"

Logon_Type=3

Resultado:

Account_Name: suporte.ti

Source_Network_Address: 10.0.5.44

Destination_Host: FIN-PC-011

Account_Name: suporte.ti

Destination_Host: RH-PC-003

Account_Name: suporte.ti

Destination_Host: ADM-PC-008

Investigando no KQL

Se eu estivesse usando o Microsoft Sentinel seria dessa forma:

Pesquisa KQL — execução de PsExec

DeviceProcessEvents

| where ProcessCommandLine contains "psexec"

| project Timestamp,

DeviceName,

InitiatingProcessAccountName,

ProcessCommandLine

Resultado:

DeviceName: IT-WS-004

User: suporte.ti

Investigando criação de serviço remoto

Sabia que o PsExec frequentemente:

- cria serviços temporários remotamente

Então comecei a procurar isso.

Pesquisa KQL — criação de serviço

```
DeviceEvents  
| where ActionType contains "ServiceInstalled"  
| project Timestamp,  
DeviceName,  
InitiatingProcessAccountName,  
FileName
```

Resultado encontrado:

Service Name:
PSEXESVC

Device:
FIN-PC-011

Mudança na severidade

Nesse momento minha preocupação aumentou bastante.

O ambiente apresentava:

- autenticação administrativa remota
- execução lateral
- criação de serviço remoto
- múltiplos hosts envolvidos

Investigando atividade suspeita pós-acesso

Depois disso comecei a procurar:

- execução de cmd.exe
- criação de usuários
- downloads
- desativação de antivírus

Pesquisa Splunk — comandos executados

```
index=windows host="FIN-PC-011"  
cmd.exe
```

Resultado:

```
whoami  
ipconfig  
net user backupadmin Pass@123 /add
```

Análise crítica

Esse foi um forte indicador de comprometimento.

O comando:

```
net user backupadmin Pass@123 /add
```

indicava:

- criação de usuário local
- possível persistência
- tentativa de manter acesso

IOC identificados

Conta utilizada

suporte.ti

Serviço criado

PSEXESVC

Usuário criado

backupadmin

Host de origem

IT-WS-004

Minhas ações como SOC Analyst N1

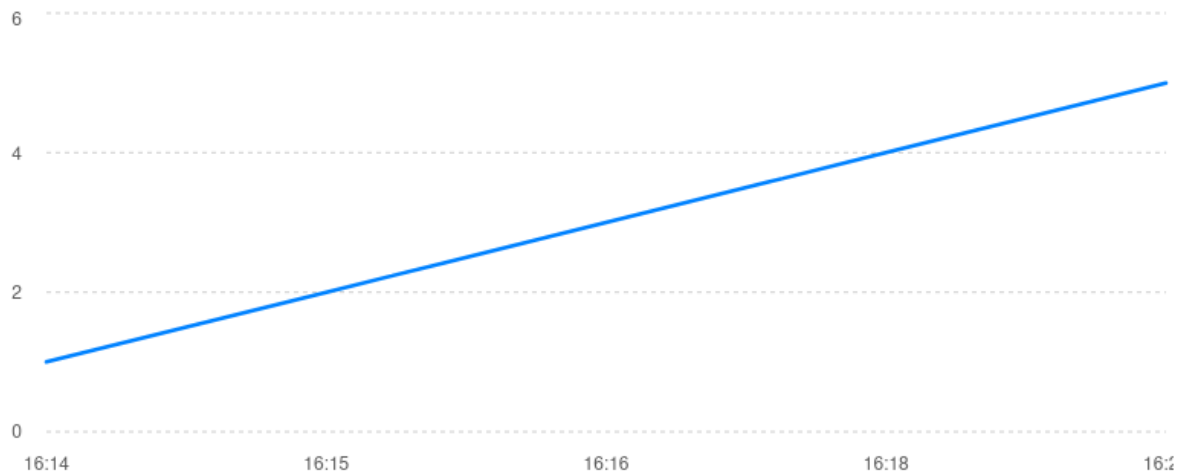
Após validar possível movimento lateral:

- Escalei imediatamente para N2
- Solicitei isolamento do host de origem
- Registrei IOC encontrados
- Recomendei reset da conta suporte.ti
- Solicitei análise dos hosts afetados
- Documentei timeline do incidente

Timeline do incidente

Timeline do Movimento Lateral

Sequência dos eventos observados durante a investigação.



Legenda:

- 1 = execução PsExec
- 2 = autenticação remota
- 3 = criação PSEXESVC
- 4 = execução cmd.exe
- 5 = criação usuário local

Relatório SOC N1

Foi identificado possível movimento lateral utilizando PsExec a partir do host IT-WS-004.

Durante a investigação foram observados:

- autenticações remotas administrativas
- execução de PsExec em múltiplos hosts
- criação do serviço PSEXESVC
- execução remota de cmd.exe
- criação do usuário backupadmin

IOC identificados:

- Conta: suporte.ti
- Serviço: PSEXESVC
- Usuário criado: backupadmin

Incidente escalado para equipe N2 e hosts encaminhados para contenção.

O que aprendi nesse laboratório

- Como investigar movimento lateral
- Como identificar uso suspeito de PsExec
- Como analisar autenticação remota
- Como investigar persistência
- Como correlacionar eventos
- Como utilizar Splunk e KQL
- Como identificar IOC em lateral movement



Autor: Paulo Cesar
Formado em Segurança da informação
linkedin.com/in/paulo-cesar-security